Org Setup and Admin Security

Project: *Okta Identity Lab |* ***Author:*** *Ismayeel Khan |* ***Date:*** *October 21, 2026 |* ***Environment:*** *Okta Integrator Free Plan*

---

1. Goal

The goal of this checkpoint was to set up my Okta organization, secure the admin account, and learn where everything lives before building anything else.

2. What is Okta?

Okta is an identity platform. Companies use it so employees can sign in once and safely reach the apps they need. In this lab I play the role of the IT admin who runs it.

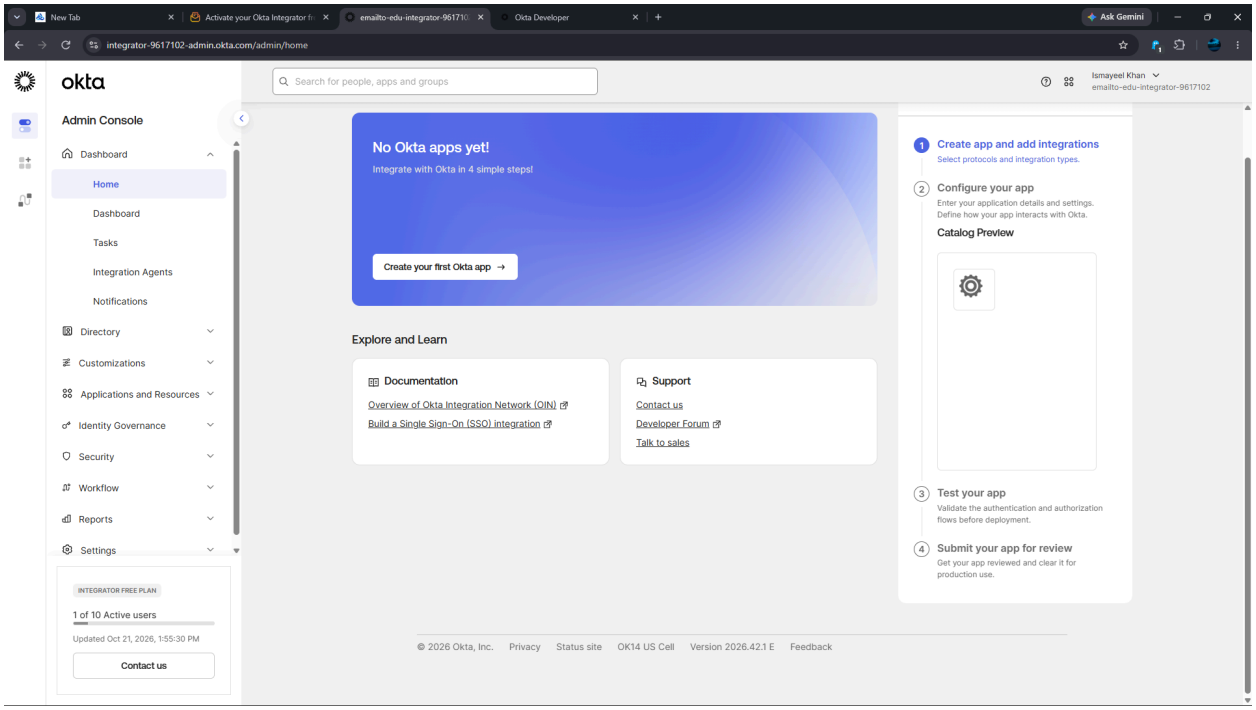
Okta has two sides:

- **Admin Console:** where admins create users, set up apps, and control security.
- **Dashboard:** what regular employees see after they sign in. It shows only the apps assigned to them.

3. Starting Point

After I activated my org, I landed on the Admin Console. It was completely empty: no apps and only one user, me.

The free plan allows only **10 active users**, so I planned the whole lab around that limit.



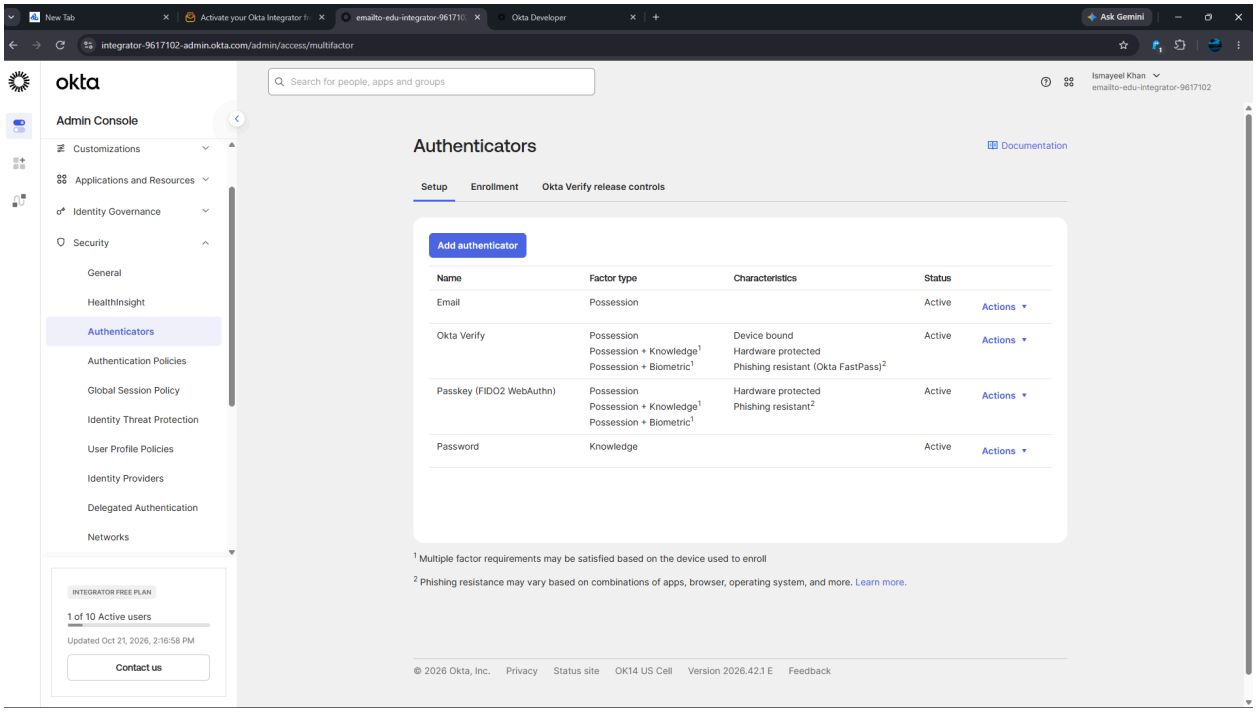
Fresh Okta org after activation. No apps have been added yet.

4. Securing the Admin Account First

The admin account can control everything in the org, so protecting it was my first job. If someone took over this account, they could create users, change policies, and read logs.

Okta supports several ways to prove who you are. These are the authenticators available in my org:

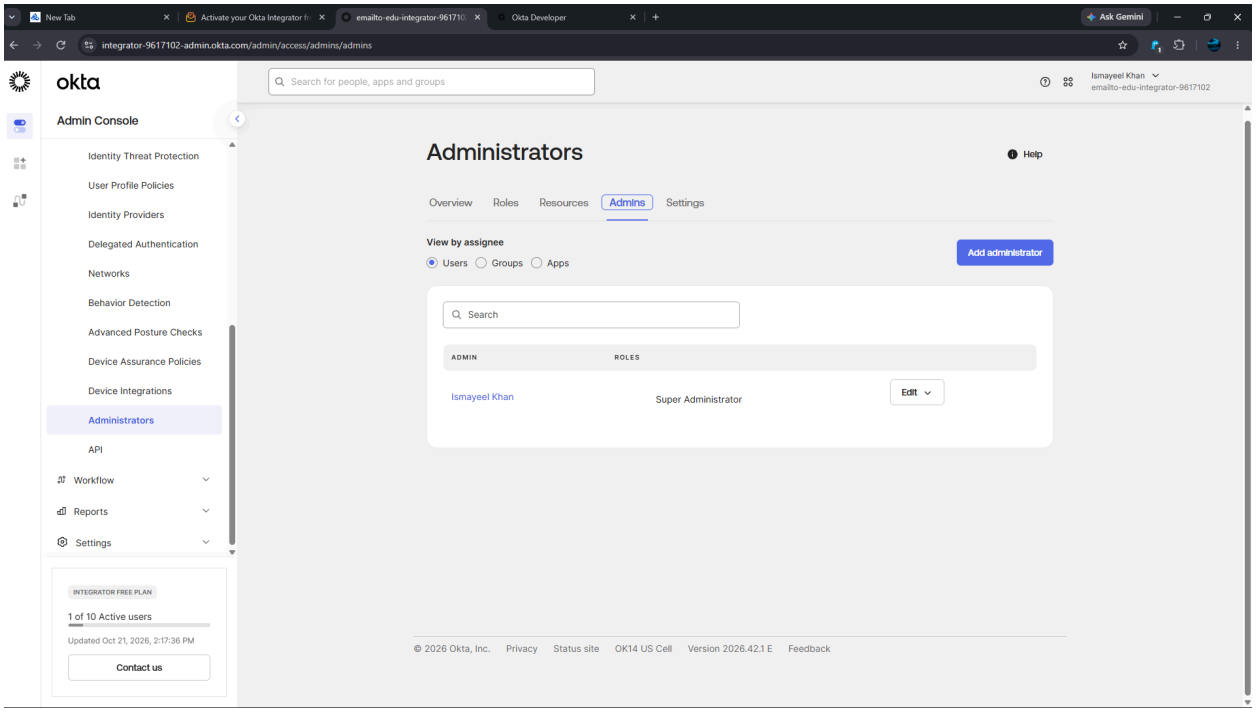
- Password
- Email
- Okta Verify
- Passkey (FIDO2 WebAuthn)



Authenticators available in the org.

My admin account signs in with a password plus a passkey as the second step. That means a stolen password alone is not enough to get in.

Next I checked who has admin rights. I am the only admin, with the **Super Administrator** role.



Administrators page showing me as the only Super Administrator.

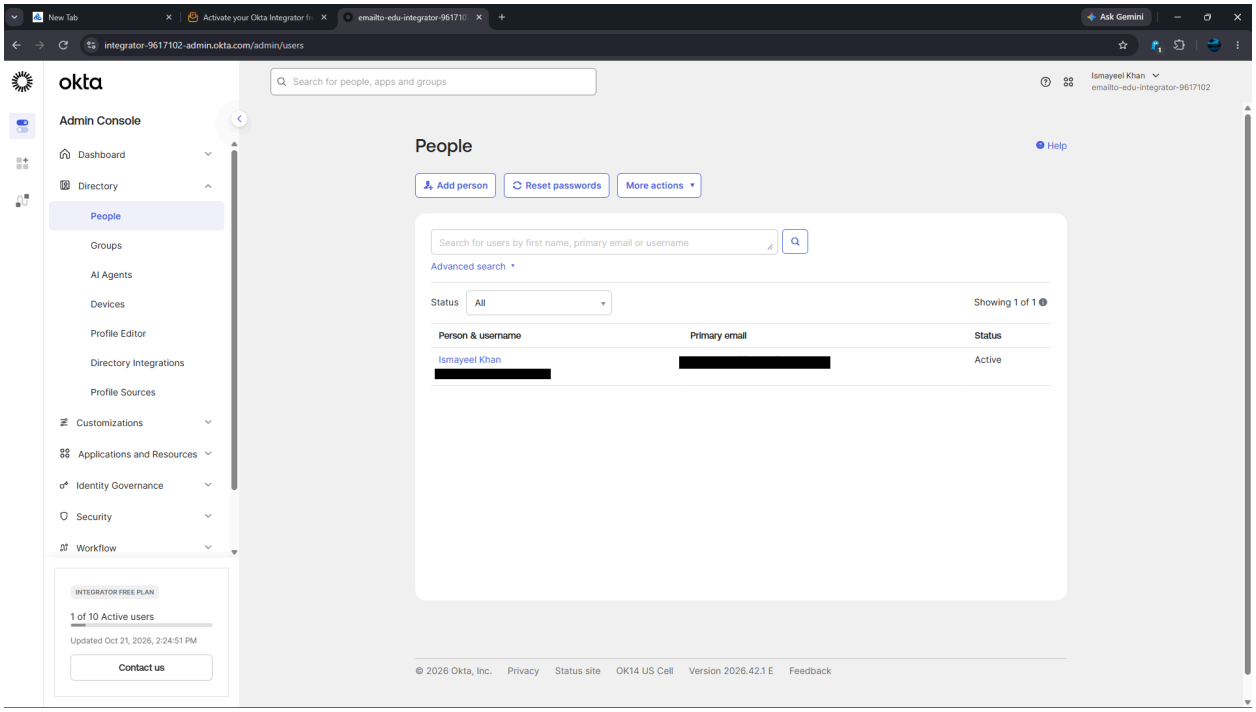
A Super Administrator has full control, so this role should be used rarely. In Checkpoint 2, I create a second admin with fewer permissions for daily helpdesk work. This idea is called **least privilege**.

5. Exploring the Admin Console

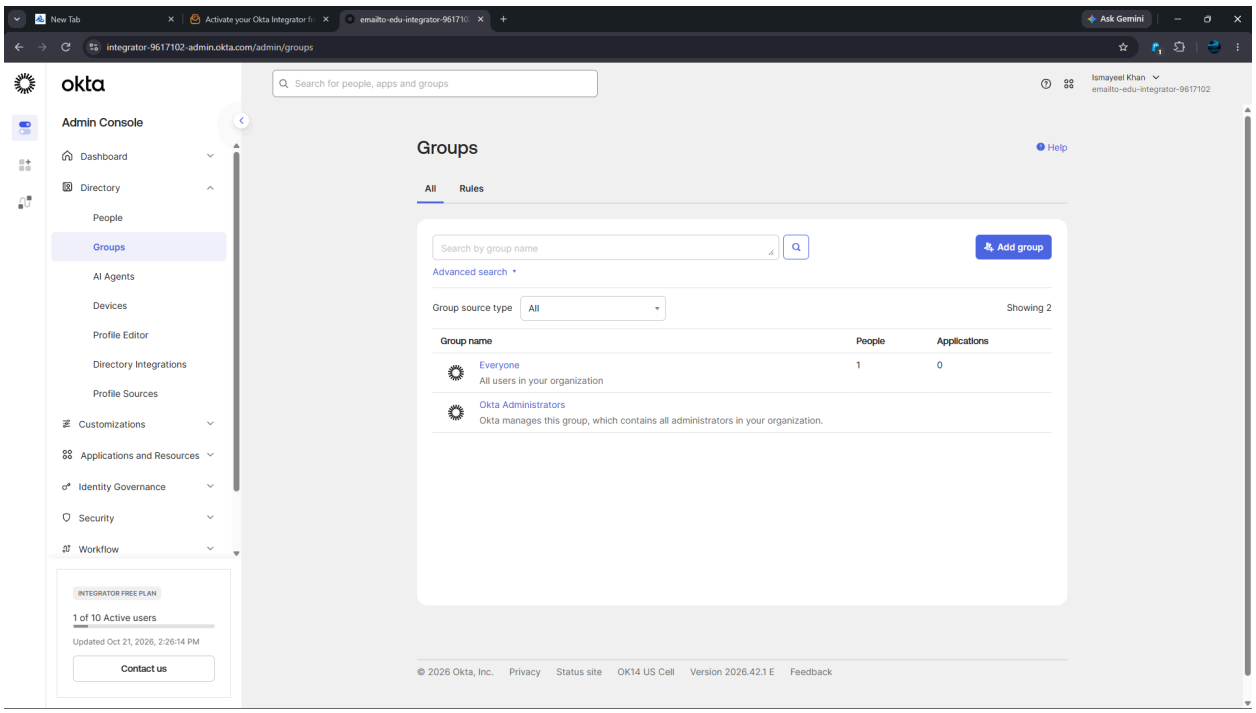
Before changing anything, I clicked through each menu to learn what lives where.

Directory

This is where people and groups live. The org started with one user (me) and two built-in groups: **Everyone** and **Okta Administrators**.



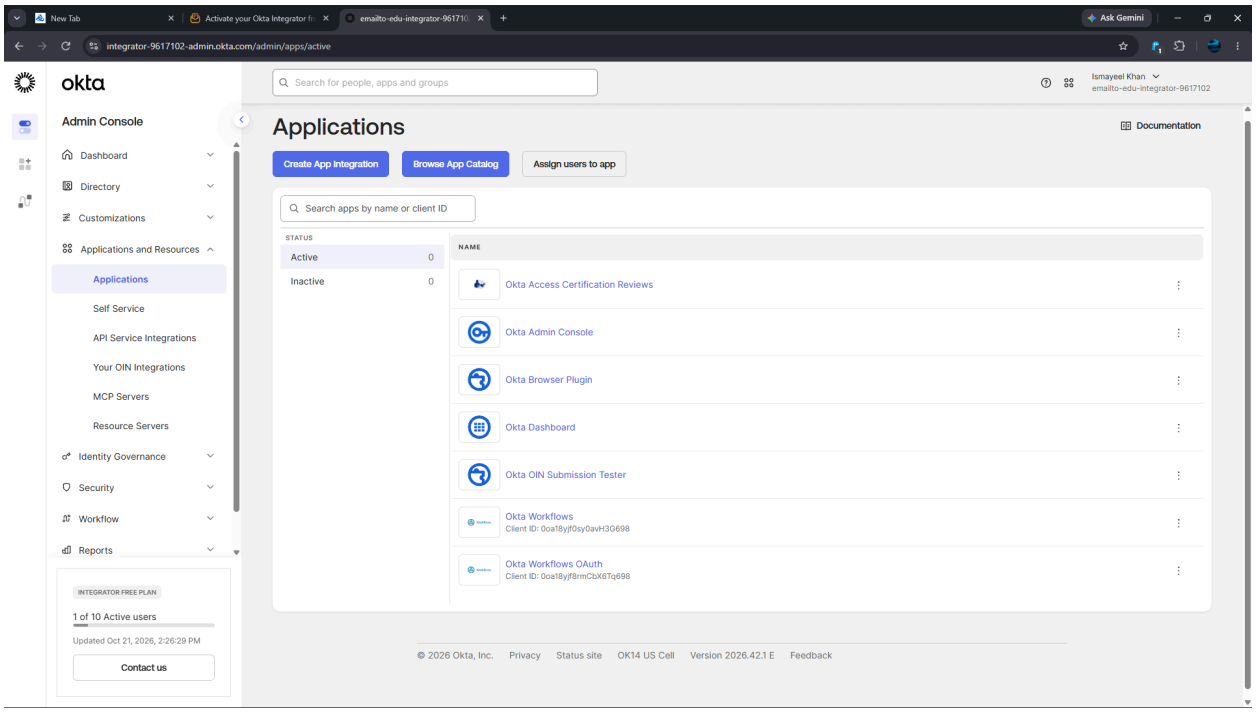
People list. I am the only user.



Groups list. Only the built-in groups exist.

Applications

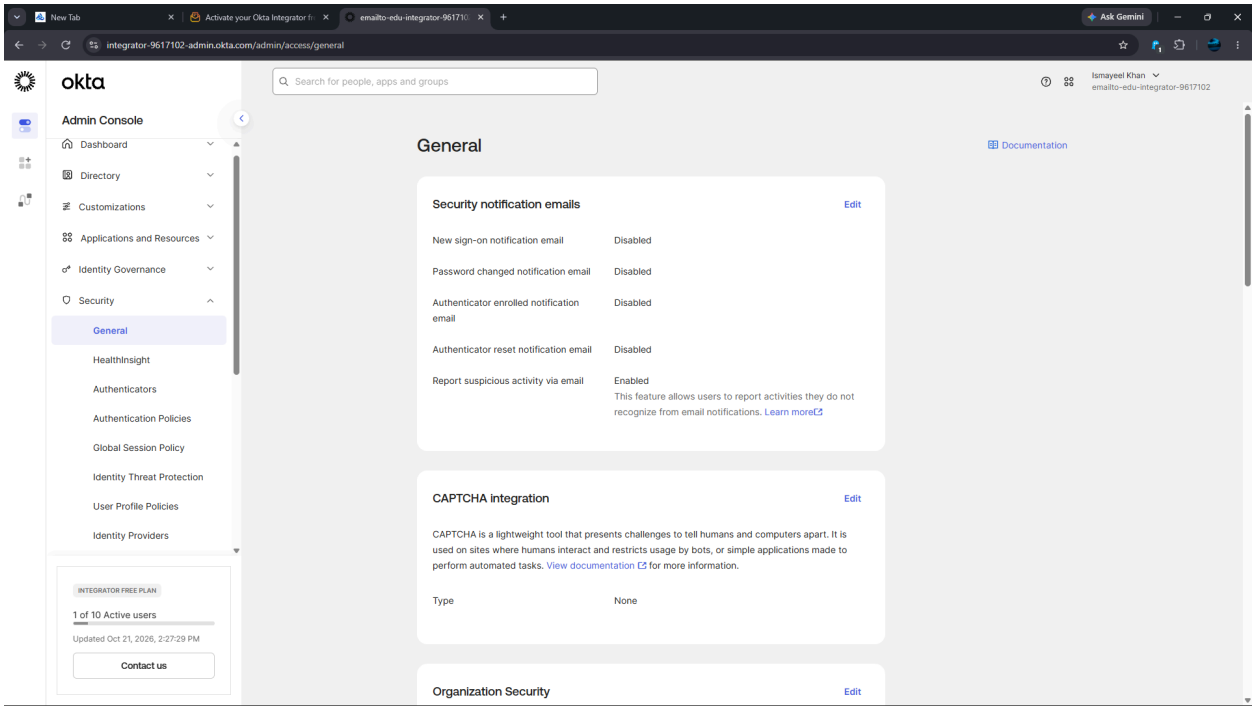
This is where apps and single sign-on are set up. Only Okta's own default apps were listed, such as the Admin Console, the Dashboard, and Okta Workflows. I had not added any apps yet.



Applications list with only Okta's default apps.

Security

This is where sign-in rules, MFA, and notifications are controlled. On the General page, four security notification emails were **disabled** by default: new sign-on, password changed, authenticator enrolled, and authenticator reset. Only "Report suspicious activity via email" was enabled.

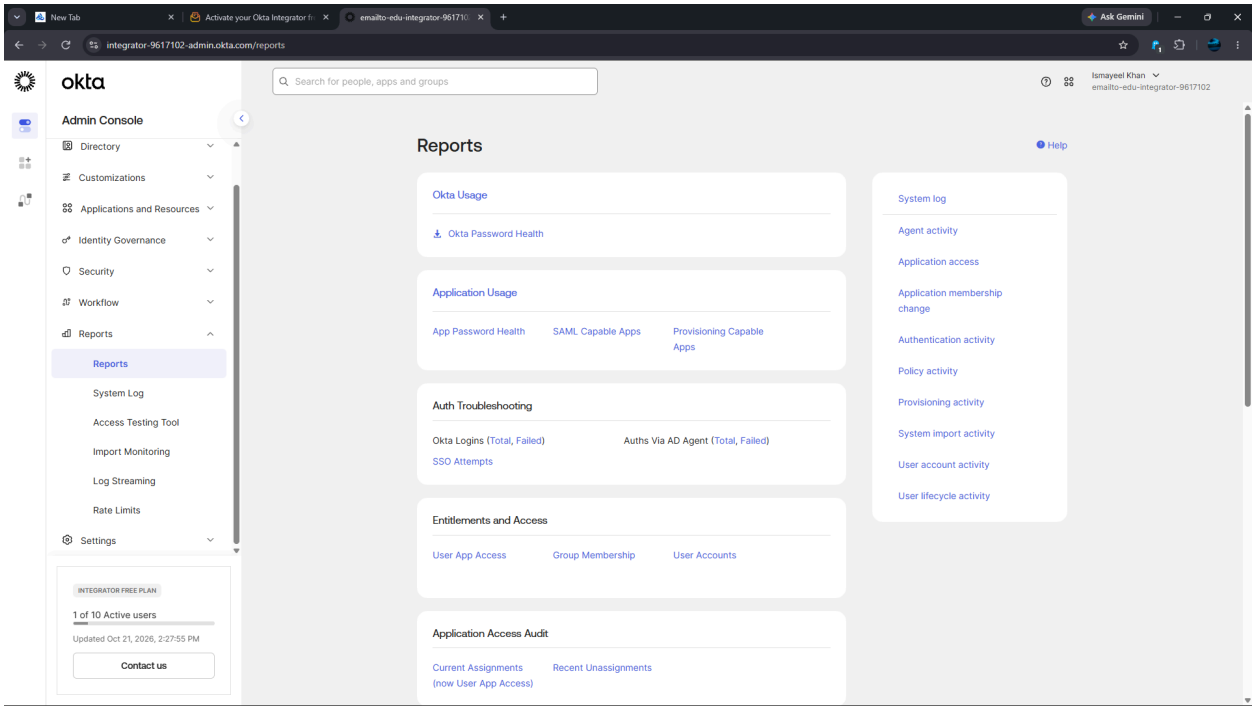


Security notification emails disabled by default.

In a real company, I would turn these on so users and admins are warned when something changes on an account. I do this in Checkpoint 4.

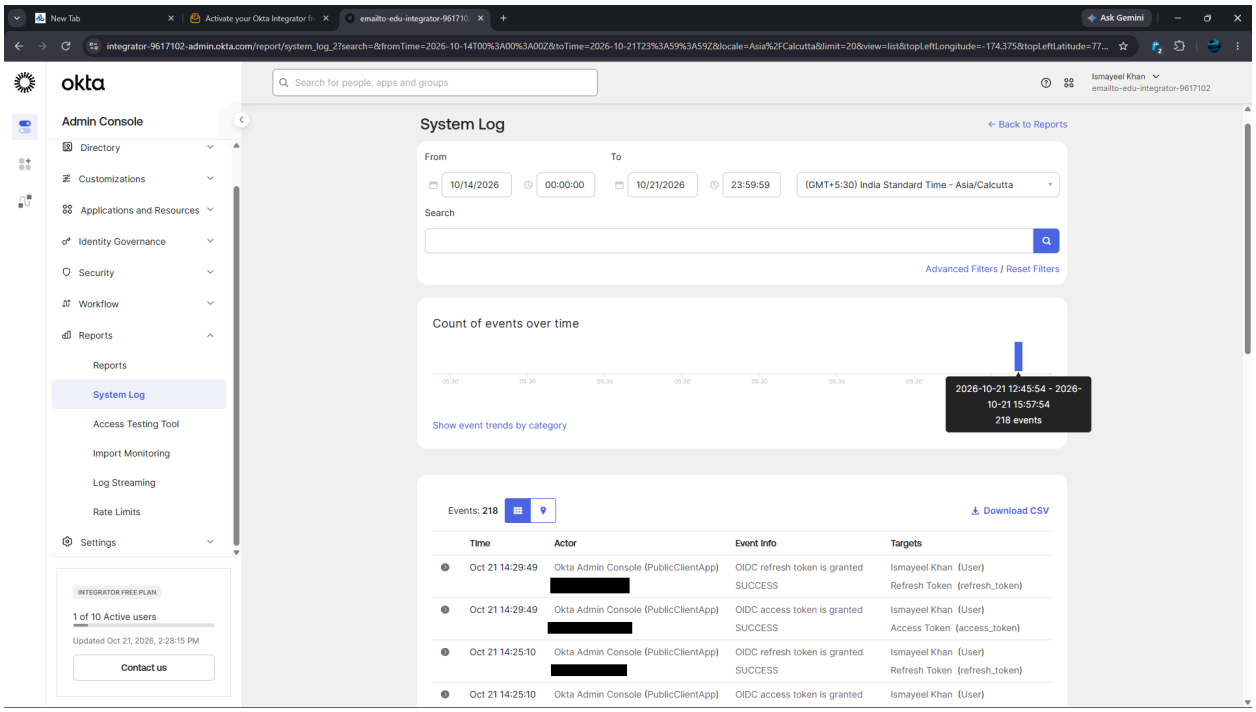
Reports and System Log

The Reports page groups ready-made reports, such as application usage and authentication troubleshooting.



Reports page.

The **System Log** records every event in the org: who did what, when, from where, and whether it succeeded. At this stage it mostly showed my own admin sign-in activity. It becomes the main troubleshooting tool in Checkpoint 6.



System Log showing early events in the org.

6. Key Concepts I Learned

- **Super Administrator vs. regular admin:** the super admin can do everything, so it should be used sparingly.
- **MFA (multi-factor authentication):** a second proof of identity on top of a password. Admins need it first because their accounts are the most valuable.
- **Admin Console vs. Dashboard:** admins manage things in one, employees use the other.
- **System Log:** the record of everything that happens, used to investigate problems.
- **Defaults are not always safe:** notification emails were off until I turned them on myself.

7. Limits and Notes

- The free plan allows **10 active users** only.
- Orgs on this plan are deactivated after about 180 days of inactivity, and there is no Okta support on the free plan.
- The plan is meant for testing, so only fake data is used in this lab.
- I created the org with a temporary email address. Temporary inboxes can disappear, and in a real company admin recovery should never depend on a throwaway inbox.

8. What I Learned and What Is Next

The main lesson from this checkpoint: **protect the admin account before building anything else.**

Next, in Checkpoint 2, I build the company inside Okta: groups, users, and a least-privilege helpdesk admin.